teamcity / security tool responses

teamcity 2023.11.3 could reach protected rest operations through an alternate jsp dispatch. the normal rest request required authentication, while the altered path returned data and, in configuration 1, created a system administrator.

configuration 1: crs 4.12.0 at pl2, inbound threshold 5 and outbound threshold 4; et-open ips in inline nfqueue mode; response and egress dlp block mode; docker isolation and wazuh telemetry.

configuration 2: crs pl3 plus an unsafe-method guard for unauthenticated post, put, patch and delete requests. the login-submit path was allowlisted. the earlier jsp-key filter is a separate archived variation, covered later.

teamcity

```
username: "scl-external-1e869346"
id: "21"
roleId: "SYSTEM_ADMIN"
scope: "g"
```

case summary

test	configuration 1	configuration 2	meaning
normal unauthenticated rest	401	401	normal route required login
altered metadata get	200	200	read access still exposed
external admin-creation post	200 / created	403 / blocked	method guard stopped the external write
altered users get	200	200	the guard did not cover reads
internal direct admin post	not used for this comparison	200 / created	the vulnerable server remained exploitable

configuration 1 / visible, allowed

modsecurity

```
time_stamp: "Fri Oct 16 02:10:29 2026"
request.method: "POST"
request.uri: "/hax?jsp=/app/rest/users;.jsp"
request.headers.Host: "waf:8080"
request.headers.X-Request-ID:
   "CVE-2024-27198-mode-a-20261016T020750Z-teamcity-external-create"
response.http_code: 200
producer.secrules_engine: "Enabled"
messages: []
```

the admin-creation transaction recorded no crs messages and returned 200. the response body contains the new user and its system-admin role, so this result establishes more than a successful metadata probe.

wazuh

```
timestamp: "2026-10-16T02:10:28.728+0000"
rule.id: "86601"
rule.level: 3
rule.description:
   "Suricata: Alert - ET WEB_SPECIFIC_APPS JetBrains TeamCity Authentication Bypass Attempt
   (CVE-2024-27198) - Vulnerability Check"
data.timestamp: "2026-10-16T02:10:26.904350+0000"
data.alert.signature_id: "2051505"
data.alert.action: "allowed"
```

et sid 2051505 identified the altered get path as a teamcity authentication-bypass attempt. the raw eve record contains the jsp query and the rest server endpoint. its action was allowed. wazuh rule 86601 reported the event at level 3; it did not turn that detection into a drop.

layer	recorded behavior	why the attack passed
crs pl2	empty message list on admin post	the altered dispatch did not match this transaction's rules
suricata 2051505	get probes identified; action allowed	the visible attempt was not blocked by that alert
response dlp	allow / no blocking match; no credentials present	content scanning did not enforce admin permissions

configuration 2 / method guard

wazuh

```
timestamp: "2026-10-16T14:17:08.937+0000"
rule.id: "110101"
rule.level: 10
rule.description: "SCL DLP blocked classified data or destination"
data.request_id: "CVE-2024-27198-mode-b-20261016T141537Z-teamcity-external-create"
data.reason: "unauthenticated_unsafe_method"
data.policy: "authenticated_state_change"
data.method: "POST"
data.path: "/hax"
data.authorization_present: "false"
data.cookie_present: "false"
```

rule 110101 carries a generic dlp block title. here its reason is unauthenticated unsafe method, with the authenticated-state-change policy. the gateway stopped the post because credential indicators were absent. the waf recorded no crs messages on that transaction; et 2051505 was still allowed. the block came from method policy.

dlp gateway

```
timestamp: "2026-10-16T14:17:09.327605+00:00"
request_id: "CVE-2024-27198-mode-b-20261016T141537Z-teamcity-external-users"
method: "GET"
path: "/hax"
query_keys: ["jsp"]
verdict: "allow"
reason: "no_blocking_match"
status: 200
```

get was outside that write-method policy, so metadata and user listing still returned 200. the attempted external account name is absent from the saved users response; old accounts were already present. a successful listing does not prove the blocked post created a user.

check	result	limit of the result
external post without credentials	403	write prevented at the gateway
allowlisted login submit	200	benign path remained usable
altered external get	200	read bypass still present
deliberate internal direct post	200	server still vulnerable; this was an internal diagnostic path

query filter and an unrelated block

wazuh

```
timestamp: "2026-10-16T02:14:52.246+0000"
rule.id: "110101"
rule.level: 10
rule.description: "SCL DLP blocked classified data or destination"
data.request_id: "CVE-2024-27198-mode-b-20261016T021222Z-teamcity-probe"
data.reason: "query_key_policy"
data.policy: "canonical_application_routing"
data.query_keys: ["jsp"]
```

the earlier record used deny_query_keys=jsp. it blocked metadata, user listing and admin creation when the routing parameter appeared. that exploit-specific filter is not the unsafe-method guard in configuration 2. their results must not be combined into a claim that pl3 stopped every bypass.

modsecurity

```
time_stamp: "Fri Oct 16 02:11:21 2026"
request.uri: "/js/ring/file-regexp-svg.c7c9e555430d62f2a662.js"
response.http_code: 403
host rule: "920350"
host message: "Host header is a numeric IP address"
sqli rule: "942120"
sqli message: "SQL Injection Attack: SQL Operator Detected"
sqli matched data:
   "Matched Data: regexp found within REQUEST_FILENAME:
   /js/ring/file-regexp-svg.c7c9e555430d62f2a662.js"
blocking rule: "949110"
blocking message: "Inbound Anomaly Score Exceeded (Total Score: 8)"
```

this 403 belongs to a javascript asset containing regexp in its filename. rule 942120 treated that word as a sql operator. together with the numeric-host warning, the total score reached 8; rule 949110 enforced the threshold of 5. this is a likely false positive on a static asset, separate from the bypass requests that passed.

what dlp recognized

these are separate synthetic classifier probes. they do not establish that this cve stole those test documents. their request ids identify the control traffic.

wazuh

```
timestamp: "2026-10-16T02:10:38.707+0000"
rule.id: "110101"
rule.level: 10
rule.description: "SCL DLP blocked classified data or destination"
data.request_id: "CVE-2024-27198-mode-a-20261016T020750Z-recognized_confidential"
data.verdict: "block"
data.reason: "request_content"
data.match_types: ["confidential_label", "synthetic_api_key", "tracked_document"]
data.bytes: "65"
```

lab rule 110101 reported the gateway's block. the reason was request content, so this was a classifier decision. the gateway enforced it; wazuh recorded it.

wazuh

```
timestamp: "2026-10-16T02:10:38.707+0000"
rule.id: "110120"
rule.level: 10
rule.description: "SCL isolated receiver recorded data movement"
data.request_id: "CVE-2024-27198-mode-a-20261016T020750Z-unrecognized_restricted"
data.component: "external-receiver"
data.bytes: "79"
```

sample	payload bytes	gateway	receiver
public control	25	201 / allowed	recorded
recognized confidential	65	403 / blocked	no receipt
unrecognized restricted	79	201 / allowed	recorded
base64 of recognized sample	56	201 / allowed	recorded

rule 110120 records receipt of data. it also fires for the public control, so its name alone does not prove theft. the unrecognized and base64 samples expose gaps in this classifier policy.

findings and fixes

rule or policy	why it appeared	outcome and visibility
et 2051505 / wazuh 86601	altered get requests matched the teamcity bypass signature	attack pattern visible; action allowed
crs 942120 and 949110	regexp asset name; score 8 exceeded threshold 5	a different asset was blocked; not proof of cve prevention
110101 / unsafe-method policy	credential indicators absent on a post	external write stopped; altered gets still passed
110101 / jsp query filter	routing query key present in the earlier variation	exploit-specific block, separate configuration
110101 / content policy	recognized classifier sample matched	known content blocked; other samples passed
110120	receiver logged a completed test transfer	movement visible, not automatically identified as theft

patch the server. use a maintained teamcity release with current security fixes. 2023.11.4 was the original fixed version. keep independent access checks around the entire host and ensure public clients cannot reach a direct backend port.

verify identity, not just credential presence. these logs show the method guard blocking requests with both indicators absent. they do not establish that a supplied cookie or header was validated. test invalid credentials and role permissions before relying on this policy. validate drop rules separately, and tune the asset false positive without disabling scoring.

references

jetbrains advisory - authentication bypass and official fix

owasp crs anomaly scoring - why a threshold block differs from a signature match

suricata rule actions - alert does not mean drop

wazuh suricata rules - generic alert handling by 86601